

Fresh Mart London

Features & Security Overview — Internal Reference

Project Overview

Fresh Mart London is a full-stack grocery delivery platform built on Next.js 16 with a Prisma-managed database. The codebase serves three distinct user surfaces — customer storefront, admin/owner back office, and staff (picker/driver) dashboards — all behind a single unified authentication system. The platform models a real UK convenience store: products with VAT and HFSS flags, age-restricted items requiring Challenge 25 verification, postcode-based delivery zones, promotions with category exclusions, driver verification workflows, and staff shift / attendance tracking. This document summarises the functional and security surface area as of the current build.

Customer-Side Functional Features

Feature	Details
Authentication	Email/password registration and login, Google OAuth, password reset, role baked into HMAC-signed session token at login time.
Catalogue Browse	Real DB-driven home page with banners, featured products, category navigation, search by name/brand/barcode, product detail page with image gallery and substitute suggestions.
Favourites	Per-user favourite list with quick re-add to cart; stored against authenticated user, not local-only.
Cart & Live Pricing	Persistent cart sidebar with live delivery fee calculation based on store settings (base fee, per-km charge, free-delivery threshold), promo code validation, subtotal/VAT/total breakdown.
Address Management	CRUD on saved addresses with postcode, lat/lng, default flag; addresses used at checkout for delivery zone enforcement.
Checkout & Payments	Stripe checkout integration, cash on delivery, bank transfer with manual verification workflow; Challenge 25 flag auto-set when basket contains age-restricted items.
Order Tracking	Order history with status pipeline (placed → picking → ready → out_for_delivery → delivered / cancelled), reorder shortcut, delivery photo URL, notification feed.
Notifications	In-app notification centre fed by order status changes, promotions, and system messages; mark-as-read and unread badge.

Admin & Staff Functional Features

Feature	Details
Owner Dashboard	KPI overview, low-stock alerts, recent orders, attendance summary; restricted to OWNER and MANAGER roles via middleware.
Product Management	Full CRUD with image upload, barcode, brand, VAT rate, HFSS flag, age restriction (Challenge 25), minimum age, aisle, stock threshold, substitute product link; CSV import/export.
Categories	Hierarchical category tree with parent/child, sort order, image, active flag; slug uniqueness enforced per store.
Order Management	List with status filter, order detail with item-level picked flag, refund action, driver assignment, batch grouping by postcode.
Customers	Customer list with order history, contact details, account active toggle.
Delivery Zones	Postcode-prefix zones (e.g. SE1, SE2) with per-zone delivery fee and minimum order value; enforced server-side at checkout.
Promotions	Percentage or fixed-amount discounts, start/end dates, usage limits, minimum order value, category scoping, optional HFSS exclusion, promo code redemption.
Drivers	Driver list with verification status (pending/approved/rejected), vehicle type/reg, right-to-work and licence document URLs, rejection reason.
Picker Dashboard	Picker-scoped order queue, item-level pick confirmation, substitute application per customer preference (closest_match / do_not_substitute).
Staff & Shifts	Employee profiles with wage type/rate, bank details; shift scheduling by role; clock-in/out attendance logs with IP and geolocation.
Wastage Logging	Per-product wastage entries with reason (expired/damaged/spoiled/other), quantity, notes, logged-by user.
Finance & Expenses	Expense ledger with category (electricity/rent/packaging/fuel/other), amount, date, receipt image; revenue analytics.
Banners	Homepage carousel management with image, link URL or category slug, sort order, active flag.
Store Settings	Owner-editable store name, address, lat/lng, phone, email, opening hours JSON, bank holiday mode (auto_close / reduced_hours / normal), delivery radius, base fee, per-km charge, free-delivery threshold.
Analytics	Sales trends, top products, category breakdown, peak hours, customer acquisition metrics.

Tech Stack

The platform is a Next.js 16 application running on the App Router with React 19 Server Components. Tailwind CSS provides styling, shadcn/ui supplies accessible primitives, and Sonner handles toast notifications. Data access is via Prisma ORM against SQLite in development and a managed PostgreSQL in production. Authentication is fully local (HMAC-signed session cookies) — no third-party auth provider. Edge Runtime middleware enforces route-level role checks. Stripe powers card payments. The codebase is deploy-ready for Vercel serverless with auto-creating SQLite schema on cold start.

Security Features

Feature	Details
Single Auth System	HMAC-signed session tokens issued at login. Supabase Auth was removed; no dual-auth conflict. One token, one source of truth.
Role-Based Access	Five roles baked into the token: CUSTOMER, DRIVER, PICKER, MANAGER, OWNER. Edge middleware inspects role claim before allowing /admin/* or /api/admin/* routes.
Edge Runtime Middleware	Runs on every request; cannot use Node crypto. Role utilities live in a separate edge-safe module (roles.ts) to avoid importing Node deps.
Password Hashing	Server-side password hashing via Node.js crypto.scrypt before storage in users.passwordHash. Plaintext never logged.
Session Expiry	Tokens carry an issued-at and expiry; middleware rejects expired tokens and forces re-login. No long-lived refresh tokens in current build.
Admin API Protection	Every /api/admin/* route verifies the caller is OWNER or MANAGER. Customer routes (/api/user/*) require an authenticated session; cross-user access is rejected.
No Mock Data Leakage	Customer-facing queries (queries.ts) return empty arrays/null when DB is unreachable — no fake products, no fallback categories. Production shows only what the owner has uploaded.
Environment Variable Isolation	Server-only secrets (DATABASE_URL, STRIPE_SECRET_KEY, HMAC secret) are never exposed to the client bundle. NEXT_PUBLIC_* prefix reserved for genuinely public values.
Delivery Zone Enforcement	Server-side postcode check at checkout against active DeliveryZone rows. Customer cannot bypass by client-side tampering.
Challenge 25 Verification	Orders containing age-restricted products carry hasChallenge25=true. Driver confirms challenge25Verified at delivery — auditable trail in order record.
Bank Transfer Verification	Manual owner verification workflow: bankTransferRef stored on order, bankTransferVerified flag set by owner after confirming receipt. Prevents premature fulfilment.
Driver Verification	Right-to-work, driving licence, and national insurance number captured at onboarding; verificationStatus gates order assignment.
Attendance Audit Trail	Clock-in/out logs include IP address and lat/lng, providing a tamper-evident staff attendance record for payroll disputes.

Pending Roadmap

The following items are tracked in the active worklog but not yet implemented:

- **Geolocation-based delivery zone:** Browser Geolocation API on customer login, Haversine distance from store lat/lng, customer-side "within radius" check, owner-editable radius in km.
- **Manual postcode entry fallback:** Geocode customer-entered postcode/address to lat/lng; if within radius, allow delivery even when device location is outside radius; if outside, block checkout.
- **Mobile responsiveness audit:** Customer storefront layout, cart sidebar, and admin tables need mobile breakpoints verified end-to-end.
- **Requirements gap analysis:** 36 items from the UK grocery delivery compliance PDF still need implementation review (see UK_GROCERY_DELIVERY_APP_LEGAL_COMPLIANCE.md).

- **Cloud DB migration:** Move from local SQLite to Vercel Postgres (or equivalent) for production persistence across serverless instances.
- **Production monitoring:** Error tracking (Sentry), uptime checks, and DB query performance monitoring are not yet wired in.